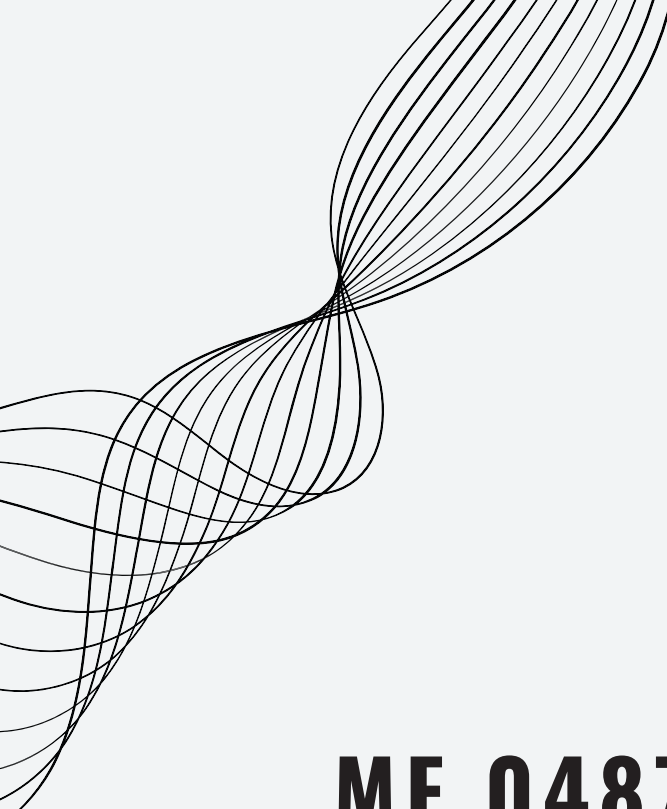




MF 0487 INFORME DE AUDITORÍA DE SEGURIDAD INFORMÁTICA - NEBULA.IO

**FECHA DE INICIO : 01 DE OCTUBRE DE 2025
EMPRESA: NEBULA.IO**

INTRODUCCIÓN:

Resumen ejecutivo :

La presente auditoría de seguridad informática en **Nebula.io** se realizó con el objetivo de **identificar, evaluar y reducir** los riesgos detectados tras el incidente crítico sufrido por el servidor principal, que fue víctima de un ataque de tipo **ransomware**.

El proceso de auditoría se llevó a cabo a partir de una copia de seguridad del sistema, situada en un entorno aislado (sandbox) y permitiendo un análisis seguro para identificar los posibles vectores de ataque responsables de la brecha de seguridad inicial.

Durante la evaluación, se identificaron cinco hallazgos principales. Se destaca especialmente la vulnerabilidad crítica **SambaCry** (CVE-2017-7494), catalogada con un **CVSS** de 9.8, la cual permite la ejecución remota de código con privilegios de usuario root.

El análisis confirmó el compromiso total del entorno evaluado, así como rastros del ransomware **RYUK V0.02a2**, evidenciando la necesidad prioritaria de aplicar las recomendaciones de seguridad propuestas en este informe.

Alcance:

Sistema auditado: 10.10.xx.xx / Servidor NEBULA (hostname: **Nebula-server**)

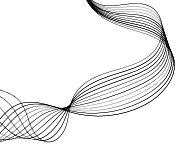
Sistema operativo: Ubuntu 14.04.6 - Kernel 4.4.0-142-generic

Puertos y servicios evaluados:

- » 53 (Domain, BIND 9.9.5-3ubuntu0.19)
- » 80 (HTTP, Bluffer)
- » 1986 (SSH, OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13)
- » 44544 (Samba smdb 3.X - 4.X)

Herramientas utilizadas: Nmap, Wireshark, Nessus, Jhon the Ripper

Limitaciones: Auditoría realizada en entorno sandbox aislado a partir de una copia de respaldo del sistema comprometido



Metodología:

1. Descubrimiento de hosts y reconocimiento inicial con Nmap
2. Escaneo de puertos y detección de servicios en ejecución
3. Enumeración de servicios y versiones
4. Análisis de vulnerabilidades mediante Nessus y Nmap
5. Recolección de evidencias
6. Recomendaciones

Hallazgos:

1) Servicio SSH vulnerable a ataques man-in-the-middle

» **Severidad:** Media

» **Descripción:** Permite a un atacante eludir controles de integridad durante el inicio de sesión, degradando la seguridad de conexión mediante el ataque conocido como Terrapin

» **Evidencia:**

SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
MEDIUM	5.9	-	-	187315	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)

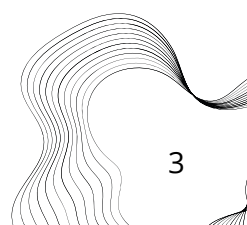
» **Impacto:** Permite a un atacante interceptar y manipular una sesión SSH, comprometiendo credenciales y datos sensibles

» **Recomendación:** Actualizar OpenSSH a una versión superior que corrija la vulnerabilidad CVE-2023-48795

2) Transferencia de zona DNS no restringida

» **Severidad:** Crítica

» **Descripción:** Es posible realizar una transferencia de zona completa (AXFR) en el servidor DNS, exponiendo todos los registros internos



» Evidencia:

```

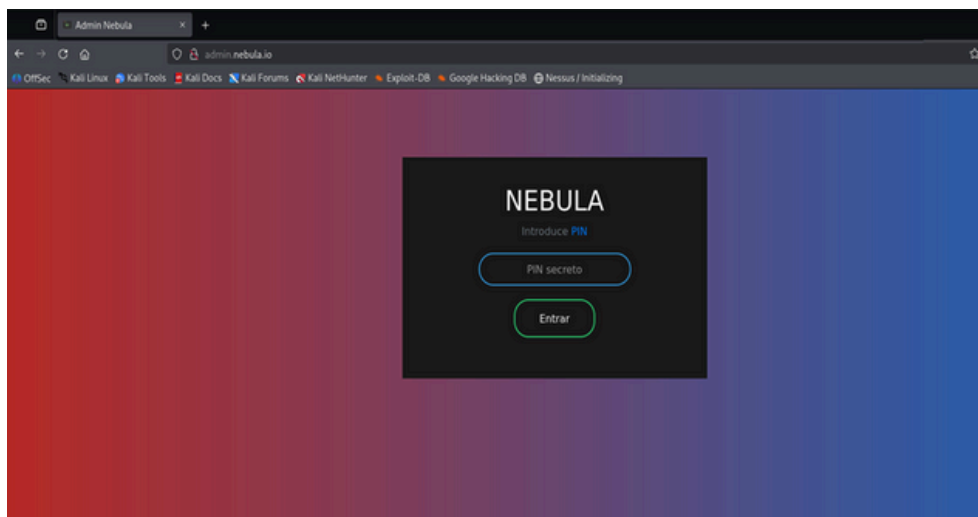
$ dig @10.10.215.196 nebula.io axfr
; <<>> DiG 9.20.9-1-Debian <<>> @10.10.215.196 nebula.io axfr
; (1 server found)
;; global options: +cmd
nebula.io. 7200 IN SOA ns1.nebula.io. admin.nebula.io. 2023102501 604800 86400 2419200 604800
nebula.io. 300 IN HINFO "Nebula Server" "Linux"
nebula.io. 301 IN TXT "nebula-verification=examplecode123"
nebula.io. 301 IN TXT "google-site-verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VlMewxA"
nebula.io. 7200 IN MX 0 mail.nebula.io.
nebula.io. 7200 IN MX 0 ASPMX.L.GOOGLE.COM.
nebula.io. 7200 IN MX 10 ALT1.ASPMX.L.GOOGLE.COM.
nebula.io. 7200 IN MX 10 ALT2.ASPMX.L.GOOGLE.COM.
nebula.io. 7200 IN MX 20 ASPMX2.GOOGLEMAIL.COM.
nebula.io. 7200 IN MX 20 ASPMX3.GOOGLEMAIL.COM.
nebula.io. 7200 IN MX 20 ASPMX4.GOOGLEMAIL.COM.
nebula.io. 7200 IN MX 20 ASPMX5.GOOGLEMAIL.COM.
nebula.io. 86400 IN NS ns1.nebula.io.
nebula.io. 86400 IN NS ns2.nebula.io.
nebula.io. 7200 IN A 192.168.150.144
sip.tcp.nebula.io. 14000 IN SRV 0 5 5060 sip.nebula.io.
144.150.168.192.IN-ADDR.ARPA.nebula.io. 7200 IN PTR www.nebula.io.
bluffer.nebula.io. 7200 IN TXT "BLUFFER{S3cr3t_DNS_Tr4nsfer_Flag}"
contact.nebula.io. 2592000 IN TXT "Para soporte, contactar a admin@nebula.io o llamar al +1 123 4567890"
deadbeef.nebula.io. 7201 IN AAAA dead:beef::1
ftp.nebula.io. 7200 IN A 192.168.150.180
mail.nebula.io. 7200 IN A 192.168.150.146
ns1.nebula.io. 86400 IN A 192.168.150.144
ns2.nebula.io. 86400 IN A 192.168.150.145
office.nebula.io. 7200 IN A 192.0.2.10
sip.nebula.io. 7200 IN A 192.168.150.147
vpn.nebula.io. 7200 IN A 198.51.100.10
www.nebula.io. 7200 IN A 192.168.150.144
xss.nebula.io. 300 IN TXT "user : bluffer"
nebula.io. 7200 IN SOA ns1.nebula.io. admin.nebula.io. 2023102501 604800 86400 2419200 604800

```

- » **Resultado:** Se obtiene información sensible como el código de verificación de Google site, números IPs, Correos electrónicos, etc...
- » **Impacto:** Permite a un atacante mapear la infraestructura interna y orientar ataques dirigidos
- » **Recomendación:** Restringir el acceso a la transferencia de zona DNS a, únicamente, IPs autorizadas

3) Exposición de directorios de administración y servicios

- » **Severidad:** Media
- » **Descripción:** Directorios y servicios administrativos accesibles sin autenticación estricta



- » **Impacto:** Podría facilitar ataques de fuerza bruta o enumeración de recursos
- » **Recomendación:** Restringir acceso por IP y habilitar autenticación fuerte. Ocultar interfaces no necesarias en producción.

4) Servicio SMB vulnerable

» **Severidad:** Crítica

» **Descripción:** Las versiones de Samba desde la 3.5.0 hasta la 4.6.4, así como 4.5.10 y 4.4.14 (y las versiones anteriores a estas), son vulnerables a CVE-2017-7494: una vulnerabilidad de ejecución remota que permite a un cliente malicioso subir una biblioteca compartida a una share escribible y provocar que el servidor la cargue y ejecute

» **Evidencia:**

```
PORT      STATE SERVICE      REASON      VERSION
44544/tcp  open  netbios-ssn  syn-ack ttl 63 Samba smbd 3.X - 4.X (workgroup: NEBULA_ROCKS)
Service Info: Host: NEBULA-SERVER
```

» **Impacto:** Un atacante podría obtener acceso remoto al sistema a través de ejecución remota de código

» **Recomendación:** Actualizar Samba a la versión más reciente y restringir el acceso al servicio exclusivamente a la red interna

5) Credenciales y usuarios expuestos

» **Severidad:** Alta

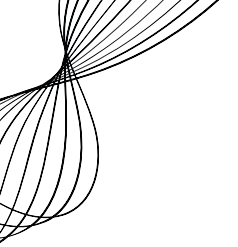
» **Descripción:** Identificación de múltiples usuarios en el sistema, incluidas cuentas con hashes de contraseñas fácilmente accesibles

» **Evidencia:**

```
cat /etc/shadow
root:$6$dTV9ZkDw$ZULnb36XSMz1fv4LzsGXZnq7FpRx3H6v3CUmD/iySvY4M/9lzVGUVv81ChJsasATlegYJLib8Ciw1/fowpi2s0:20014:0:99999:7:::
daemon:*:17959:0:99999:7:::
bin:*:17959:0:99999:7:::
sys:*:17959:0:99999:7:::
sync:*:17959:0:99999:7:::
games:*:17959:0:99999:7:::
man:*:17959:0:99999:7:::
lp:*:17959:0:99999:7:::
mail:*:17959:0:99999:7:::
news:*:17959:0:99999:7:::
uucp:*:17959:0:99999:7:::
proxy:*:17959:0:99999:7:::
www-data:*:17959:0:99999:7:::
backup:*:17959:0:99999:7:::
list:*:17959:0:99999:7:::
irc:*:17959:0:99999:7:::
gnats:*:17959:0:99999:7:::
nobody:*:17959:0:99999:7:::
libuuid:!:17959:0:99999:7:::
syslog:*:17959:0:99999:7:::
messagebus:*:20014:0:99999:7:::
landscape:*:20014:0:99999:7:::
guakamole:$6$kvXyIMLn$A6bPHFDkYFqd/dS58eGsJmK2lYnLEQxtgYX6H/6WxdC.V21j/P8IaseqnKibDBq1PkdmRqgPO2CU3dd/U6gCl1:20014:0:99999:7:::
sshd:*:20014:0:99999:7:::
bind:*:20021:0:99999:7:::
bluffer:$6$XDj2Khlp$3050apIJ/1wbvCbFCRFWQsyVgp3BXTB.sQfQLGvIfpLHAulD0FXADfugbba8uPFc93CVUZTT8GZvdvOI17mWc/:20186:0:99999:7:::
```

» **Impacto:** Aumenta la superficie de ataque y la posibilidad de escalamiento de privilegios

» **Recomendación:** Cambiar todas las contraseñas, implementar políticas de gestión de accesos y auditar la existencia de cuentas activas innecesarias



Recomendaciones:

Prioridad	Acción
Alta	Actualizar OpenSSH y Samba a versiones corregidas
Alta	Restringir transferencia de zona DNS solo a administradores
Alta	Cambiar inmediatamente todas las contraseñas y revisar cuentas
Media	Implementar autenticación fuerte en paneles administrativos
Media	Revisar y mejorar configuración de firewall y segmentación de red
Baja	Realizar formación periódica sobre ciberseguridad para los usuarios

Conclusión:

El laboratorio ha permitido identificar debilidades relevantes en la seguridad de Nebula.io y ha ofrecido una hoja de ruta factible para mitigar los principales riesgos detectados.

El ejercicio demuestra la importancia de las auditorías periódicas y la aplicación continua de mejores prácticas de ciberseguridad.

Anexos:

Comandos utilizados:

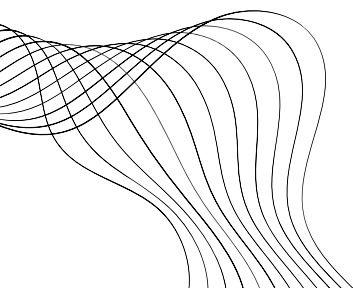
```
cat, cd, ls, file, chmod
nmap -sn 10.10.215.196
nmap -sS -p- 10.10.215.196 -vv
nmap -sS -sV -p53,80,1986 10.10.215.196 -vv
ssh -p 1986 bluffer@10.10.215.196
compgen -u
nslookup -type=TXT nebula.io 10.10.155.249
hostname
uname -a
getent
```

└──(kali㉿kali)-[~]

└─\$ dig axfr @10.10.155.249 nebula.io

```
; <<>> DiG 9.20.9-1-Debian <<>> axfr @10.10.155.249 nebula.io
; (1 server found)
;; global options: +cmd
nebula.io.      7200  IN      SOA      ns1.nebula.io. admin.nebula.io. 2023102501
604800 86400 2419200 604800
nebula.io.      300   IN      HINFO    "Nebula Server" "Linux"
nebula.io.      301   IN      TXT      "nebula-verification=examplecode123"
nebula.io.      301   IN      TXT      "google-site-
verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VIMewxA"
nebula.io.      7200  IN      MX       0 mail.nebula.io.
nebula.io.      7200  IN      MX       0 ASPMX.L.GOOGLE.COM.
nebula.io.      7200  IN      MX       10 ALT1.ASPMX.L.GOOGLE.COM.
nebula.io.      7200  IN      MX       10 ALT2.ASPMX.L.GOOGLE.COM.
nebula.io.      7200  IN      MX       20 ASPMX2.GOOGLEMAIL.COM.
nebula.io.      7200  IN      MX       20 ASPMX3.GOOGLEMAIL.COM.
nebula.io.      7200  IN      MX       20 ASPMX4.GOOGLEMAIL.COM.
nebula.io.      7200  IN      MX       20 ASPMX5.GOOGLEMAIL.COM.
nebula.io.      86400  IN      NS       ns1.nebula.io.
nebula.io.      86400  IN      NS       ns2.nebula.io.
nebula.io.      7200  IN      A        192.168.150.144
_sip._tcp.nebula.io. 14000 IN      SRV      0 5 5060 sip.nebula.io.
144.150.168.192.IN-ADDR.ARPA.nebula.io. 7200 IN      PTR      www.nebula.io.
bluffer.nebula.io. 7200  IN      TXT      "BLUFFER{S3cr3t_DNS_Tr4nsfer_Flag}"
contact.nebula.io. 2592000 IN      TXT      "Para soporte, contactar a
admin@nebula.io o llamar al +1 123 4567890"
deadbeef.nebula.io. 7201  IN      AAAA     dead:beef::1
ftp.nebula.io.   7200  IN      A        192.168.150.180
mail.nebula.io.  7200  IN      A        192.168.150.146
ns1.nebula.io.   86400  IN      A        192.168.150.144
ns2.nebula.io.   86400  IN      A        192.168.150.145
office.nebula.io. 7200  IN      A        192.0.2.10
sip.nebula.io.   7200  IN      A        192.168.150.147
vpn.nebula.io.   7200  IN      A        198.51.100.10
www.nebula.io.   7200  IN      A        192.168.150.144
xss.nebula.io.   300   IN      TXT      "user : bluffer"
nebula.io.      7200  IN      SOA      ns1.nebula.io. admin.nebula.io. 2023102501
604800 86400 2419200 604800
;; Query time: 51 msec
;; SERVER: 10.10.155.249#53(10.10.155.249) (TCP)
;; WHEN: Thu Oct 02 12:13:15 EDT 2025
;; XFR size: 30 records (messages 1, bytes 961)
```

143.110.250.149



» **Contenido etc/passwd:**

guakamole:x:1000:1000:David Kline,,,:/home/guakamole:/bin/bash

» **Hashes usuarios encontrados:**

guakamole:\$6\$kVXyIMLn\$A6bPHFDkYFqd/dS58eGsJmK2lYnlEQxtgYX6H/6WxdC.V21j/P
8laseqnKibDBq1PkdmRqgPO2CU3dd/U6gCl1:20014:0:99999:7:::
bluffer:\$6\$XDj2Khlp\$3O50apIj/1wbvCbfcRfWQsyVgp3BXTB.sQfQLGvIfpLHAulDOFXADf
ugbba8uPFc93CVUZTTBGZvdvOIl7mWc/:20186:0:99999:7:::

Adjunto logs y report de nessus in :

» nmap_vuln.txt

- sha256

f17635fe82bae3634ea2029dea6d663f4b2c0c7acf5270dbed893577025cfbb2

» Nessus_scan.pdf

-sha256

7ad520aed6f6e5857292d38e8492619353e2712eee4f69ba966f08d36ee2b6d1